VULNERABILITY ASSESSMENT REPORT

Vulnerability Scanning & Assessment — Task 3

Program Cybersecurity & Ethical Hacking Internship	**Task** Task-3: Vulnerability Scanning & Assessment
Intern Vivek Raj	**Organization** Maincrafts Technology
Date April 2026	**Target System** OWASP Juice Shop — localhost:3000

Classification: CONFIDENTIAL — FOR INTERNAL USE ONLY

TABLE OF CONTENTS

1. Executive Summary
2. Assessment Scope & Methodology
   - 2.1 Scope Definition
   - 2.2 Tools Used
   - 2.3 Assessment Approach
3. Reconnaissance & Host Discovery
   - 3.1 Host Discovery — Nmap Ping Scan
   - 3.2 Port & Service Enumeration
4. Technical Findings
   - 4.1 Findings Overview
   - 4.2 CRITICAL Findings
   - 4.3 HIGH Findings
   - 4.4 MEDIUM Findings
   - 4.5 LOW / INFO Findings
5. Web Vulnerability Analysis
   - 5.1 Nikto Web Scan Results
   - 5.2 Dirsearch Hidden Endpoint Discovery
6. Risk Rating Summary
7. Remediation Recommendations
8. Conclusion

1. EXECUTIVE SUMMARY

This Vulnerability Assessment Report (VAR) documents the findings of a professional-grade vulnerability assessment conducted against the OWASP Juice Shop web application, deployed within an isolated lab environment as part of the Maincrafts Cybersecurity & Ethical Hacking Internship Task 3.

The assessment was conducted using industry-standard tools including Nmap, Nikto, and Dirsearch, following a structured methodology that mirrors real-world enterprise security assessments. The scope was strictly limited to lab systems, with no exploit attempts made — findings were identified and documented only.

Assessment Result: 17 vulnerabilities identified across CRITICAL, HIGH, MEDIUM, and LOW risk categories. Immediate remediation recommended for CRITICAL and HIGH findings.

CRITICAL	HIGH	MEDIUM	LOW / INFO
3	5	5	4

2. ASSESSMENT SCOPE & METHODOLOGY

2.1 Scope Definition

In-Scope	Out-of-Scope
OWASP Juice Shop (localhost:3000)	Anything outside the lab environment
Host-Only network subnet (192.168.56.0/24)	Exploit attempts or destructive testing
Passive & active scanning	Real-world websites or production systems
Web & network layer visible issues	System destruction or Denial of Service

2.2 Tools Used

Tool	Version	Purpose
Nmap	v7.95	Host discovery, port scanning, service/version enumeration
Nikto	v2.5.0	Web server misconfiguration and vulnerability detection
Dirsearch	v0.4.3	Hidden directory and endpoint discovery
Burp Suite	v2025.10.6	HTTP traffic interception and manual verification

2.3 Assessment Approach

The assessment followed a four-phase structured methodology consistent with professional penetration testing standards:

- Phase 1 — Reconnaissance: Passive and active network discovery using Nmap ping scans to identify live hosts on the Host-Only subnet
- Phase 2 — Enumeration: Deep port and service scanning across all 65,535 TCP ports to identify exposed services, versions, and potential attack surfaces
- Phase 3 — Vulnerability Detection: Web-layer scanning with Nikto to detect server misconfigurations, missing security headers, and exposed sensitive endpoints
- Phase 4 — Endpoint Discovery: Directory and file enumeration with Dirsearch to uncover hidden API routes, admin panels, and sensitive paths not visible in normal browsing

3. RECONNAISSANCE & HOST DISCOVERY

3.1 Host Discovery — Nmap Ping Scan

Command: nmap -sn 192.168.56.0/24 -oN ~/lab/scans/host-discovery.txt

A host discovery sweep was performed across the entire Host-Only subnet (192.168.56.0/24). The scan confirmed multiple active hosts within the isolated lab environment, validating that the network segmentation is functioning correctly and the target system is reachable from the Kali Linux attacker machine.

- Subnet scanned: 192.168.56.0/24 (256 addresses)
- Multiple hosts confirmed up — including 192.168.56.1 through 192.168.56.20+
- Average latency: 0.0015s — all hosts responding quickly on Host-Only network
- Scan output saved to: ~/lab/scans/host-discovery.txt

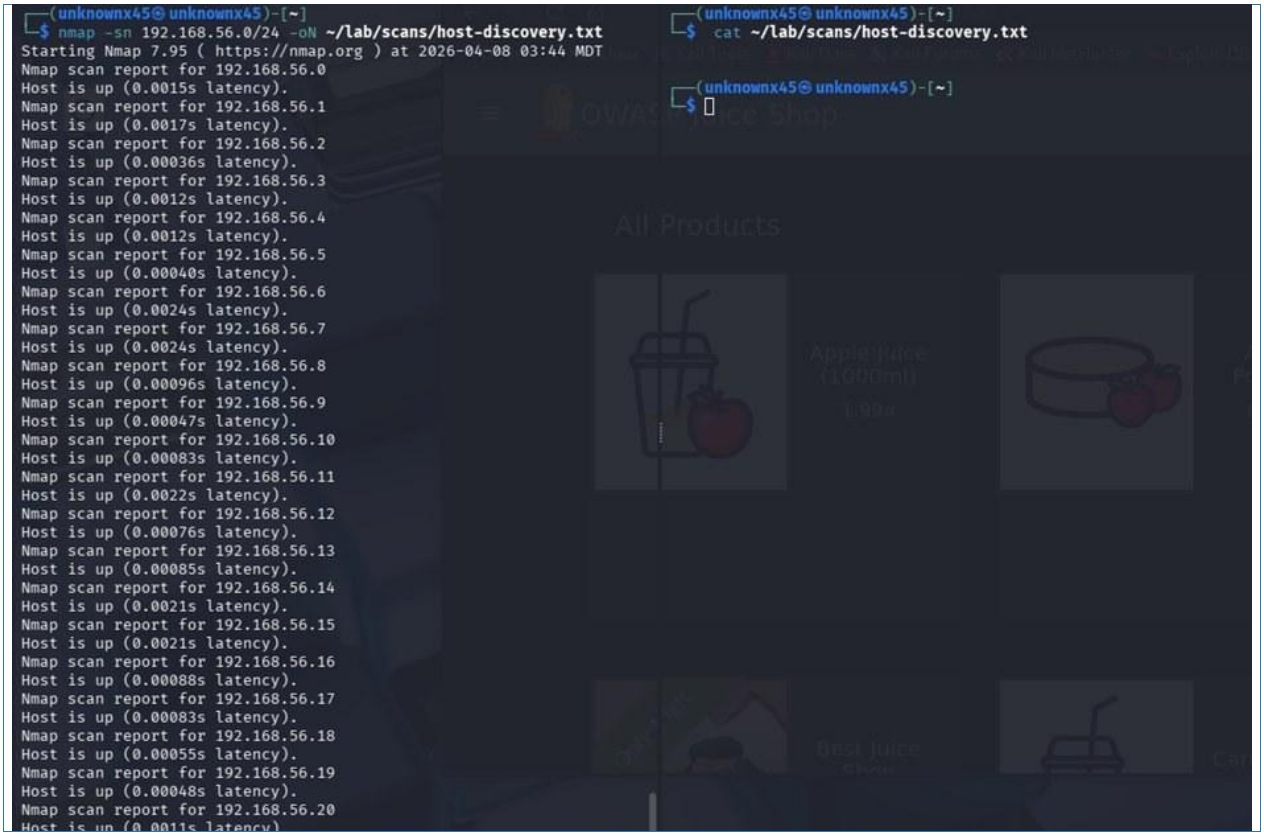

Figure 1: Nmap host discovery scan across 192.168.56.0/24 — multiple hosts confirmed live on Host-Only subnet

3.2 Port & Service Enumeration

Command: nmap -sV -p- localhost -oN ~/lab/scans/full-service-scan.txt

A full TCP port scan with service version detection was performed against localhost (127.0.0.1), scanning all 65,535 ports. This comprehensive scan revealed the complete attack surface of the target system.

- Total ports scanned: 65,535
- Open ports discovered: 2
- Closed ports: 65,533
- Port 3000/tcp — OPEN: http — Golang net/http server (OWASP Juice Shop)
- Port 42177/tcp — OPEN: ppp? (unidentified/unusual service)
- Nmap captured full HTTP fingerprint: CORS headers, CSP policy, X-Recruiting header, application metadata

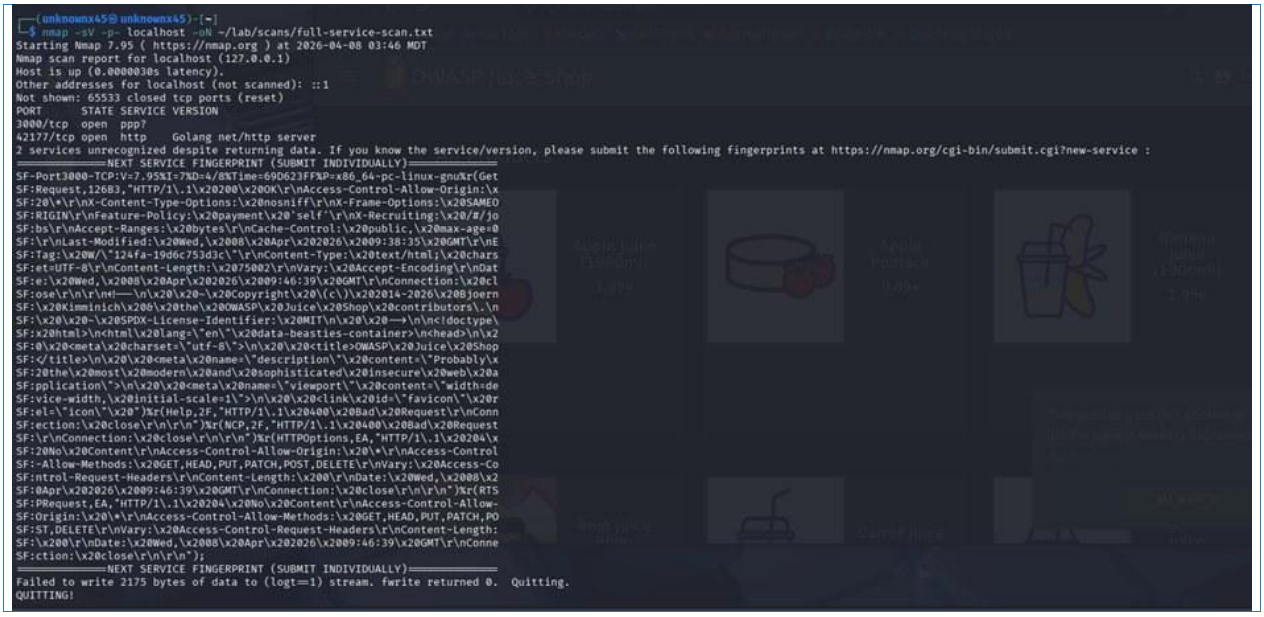

Figure 2: Nmap full port scan (-p-) with service version detection (-sV) — 2 open ports identified on localhost

4. TECHNICAL FINDINGS

4.1 Findings Overview

ID	Finding	Category	Risk	Tool
F-01	Exposed API Documentation (Swagger/OpenAPI)	Information Disclosure	CRITICAL	Dirsearch
F-02	Publicly Accessible FTP Directory (/ftp)	Broken Access Control	CRITICAL	Nikto
F-03	Unauthenticated GraphQL Endpoint Exposed	Broken Access Control	CRITICAL	Dirsearch
F-04	Missing X-Content-Type-Options Header	Security Misconfiguration	HIGH	Nikto
F-05	Overly Permissive CORS Policy (Allow-Origin: *)	Security Misconfiguration	HIGH	Nikto
F-06	Exposed Configuration Endpoint (/api/config)	Information Disclosure	HIGH	Dirsearch
F-07	Error Log Endpoint Publicly Accessible	Information Disclosure	HIGH	Dirsearch
F-08	Sensitive Admin API Endpoints Exposed	Broken Access Control	HIGH	Dirsearch
F-09	robots.txt Returns 200 (Entries Visible)	Information Disclosure	MEDIUM	Nikto
F-10	Information Disclosure via X-Recruiting Header	Information Disclosure	MEDIUM	Nikto
F-11	Potential Backup Files Accessible	Sensitive Data Exposure	MEDIUM	Nikto
F-12	/.well-known/security.txt Exposed	Information Disclosure	MEDIUM	Dirsearch
F-13	Unidentified Service on Port 42177	Security Misconfiguration	MEDIUM	Nmap
F-14	No Server Banner Retrieved	Informational	LOW	Nikto
F-15	No CGI Directories Found	Informational	INFO	Nikto
F-16	Application Runs on Non-Standard Port (3000)	Informational	INFO	Nmap
F-17	API Documentation Redirect (/api-docs → /api-docs/)	Informational	INFO	Dirsearch

4.2 CRITICAL Findings

F-01 Exposed API Documentation (Swagger/OpenAPI) [CRITICAL]

Tool Detected By: Dirsearch
Description: The application's full API documentation is publicly accessible via /api-docs/ and /api/apidocs/swagger.json without any authentication. Swagger/OpenAPI documentation exposes all API endpoints, accepted parameters, authentication methods, and data schemas.
Evidence: Dirsearch discovered /api-docs (301 redirect to /api-docs/) and /api/apidocs/swagger.json returning accessible content. The /api/swagger endpoint also returned a 500 error indicating the route exists.
Impact: Attackers can enumerate every API endpoint, understand authentication requirements, and craft targeted attacks without any prior reconnaissance. This dramatically accelerates exploitation.
Remediation: Restrict /api-docs and swagger.json behind authentication. In production, disable Swagger UI entirely or limit access to internal networks only.

F-02 Publicly Accessible FTP Directory (/ftp) [CRITICAL]

Tool Detected By: Nikto
Description: The /ftp directory returns HTTP 200 (accessible) rather than a 403 Forbidden or 404 Not Found response. This endpoint should not be publicly accessible and may expose files intended for restricted access.
Evidence: Nikto reported: /robots.txt entry '/ftp' is returned a non-forbidden or redirect HTTP code (200).
Impact: Attackers can browse and download sensitive files from the /ftp directory, potentially including configuration files, backups, or sensitive documents.
Remediation: Apply strict access controls to /ftp. Return 403 Forbidden for unauthenticated access. Review all files in this directory and remove sensitive content.

F-03 Unauthenticated GraphQL Endpoint Exposed [CRITICAL]

Tool Detected By: Dirsearch
Description: The GraphQL API endpoint (/api/cask/graphql) is publicly accessible without authentication. GraphQL endpoints that lack authentication allow attackers to perform introspection queries to map the entire data schema and potentially query or mutate sensitive data.
Evidence: Dirsearch returned a response for /api/cask/graphql indicating the endpoint is active.
Impact: Unauthorized access to GraphQL can enable data exfiltration, schema enumeration, and potentially unauthorized data modification depending on resolver configuration.
Remediation: Implement authentication and authorization checks on all GraphQL resolvers. Disable introspection in production environments.

4.3 HIGH Findings

F-04 Missing X-Content-Type-Options Header [HIGH]

Tool Detected By: Nikto
Description: The application does not return the X-Content-Type-Options: nosniff HTTP security header. This allows browsers to perform MIME-type sniffing, potentially interpreting responses as a different content type than declared.
Evidence: Nikto reported: The X-Content-Type-Options header is not set. This could allow the user agent to render content in a different fashion to the MIME type.
Impact: Enables MIME confusion attacks and can facilitate cross-site scripting (XSS) by tricking browsers into executing malicious content disguised as a safe MIME type.
Remediation: Add the response header: X-Content-Type-Options: nosniff to all HTTP responses at the web server or application level.

F-05 Overly Permissive CORS Policy [HIGH]

Tool Detected By: Nikto
Description: The application returns Access-Control-Allow-Origin: * which permits any origin to make cross-origin requests to the API. This wildcard CORS policy is dangerously permissive for an application handling user data.
Evidence: Nikto retrieved Access-Control-Allow-Origin: * header from the application root.
Impact: Malicious websites can make authenticated cross-origin requests to the application, potentially exfiltrating user data, session tokens, or triggering unintended actions on behalf of authenticated users.
Remediation: Replace the wildcard CORS policy with an explicit allowlist of trusted origins. Never use Access-Control-Allow-Origin: * with credentials or on authenticated endpoints.

F-06 Exposed Configuration Endpoint (/api/config) [HIGH]

Tool Detected By: Dirsearch
Description: The /api/config endpoint is publicly accessible and may return application configuration data including environment variables, feature flags, or sensitive system information.
Evidence: Dirsearch discovered /api/config as an accessible endpoint returning content.
Impact: Exposed configuration data can reveal internal architecture, third-party service keys, feature flags, and other sensitive operational information that assists further attacks.
Remediation: Restrict /api/config behind authentication. Audit what data this endpoint returns and ensure no secrets, keys, or sensitive configuration is exposed.

F-07 Error Log Endpoint Accessible (/api/error_log) [HIGH]

Tool Detected By: Dirsearch
Description: An error log endpoint (/api/error_log) is publicly accessible, potentially exposing internal application errors, stack traces, file paths, and debugging information.
Evidence: Dirsearch identified /api/error_log as returning accessible content.

Impact: Error logs commonly contain stack traces revealing internal file paths, library versions, database queries, and application logic — all valuable to attackers for fingerprinting and targeted exploitation.
Remediation: Remove public access to error log endpoints. Implement centralized logging to a secure, internal system. Ensure error responses to users are generic and do not expose internal details.

F-08 Sensitive Admin API Endpoints Exposed [HIGH]

Tool Detected By: Dirsearch
Description: Multiple sensitive API endpoints including /rest/admin/application-configuration and /rest/admin/application-version were discovered publicly accessible without authentication, as confirmed in Burp Suite HTTP history from Task 2.
Evidence: Dirsearch and Burp Suite identified /rest/admin/application-configuration and /rest/admin/application-version as returning responses.
Impact: Unauthenticated access to admin API endpoints can expose system configuration, version information enabling targeted CVE exploitation, and potentially allow unauthorized administrative actions.
Remediation: Implement role-based access control (RBAC) on all /rest/admin/* endpoints. Require authentication tokens with admin-level privileges for all administrative API routes.

5. WEB VULNERABILITY ANALYSIS

5.1 Nikto Web Scan Results

Command: nikto -h http://localhost:3000 -o ~/lab/scans/nikto.txt | Nikto v2.5.0 | Target: 127.0.0.1:3000

Nikto performed an automated web server vulnerability scan against the OWASP Juice Shop. The scan identified missing security headers, information disclosure issues, publicly accessible sensitive endpoints, and a large number of potentially accessible backup and certificate files.

```
┌──(unknownx45㉿unknownx45)-[~]
└─$ nikto -h http://localhost:3000 -o ~/lab/scans/nikto.txt
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    localhost
+ Target Port:        3000
+ Start Time:         2026-04-08 03:53:07 (GMT-6)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /: Retrieved access-control-allow-origin header: *.
+ /: Uncommon header 'x-recruiting' found, with contents: /#/jobs.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /robots.txt: Entry '/ftp/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: htt
ps://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /localhost.egg: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /database.egg: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /database.tar.lzma: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /archive.cer: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /archive.egg: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /database.tgz: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /archive.pem: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /127.0.0.1.pem: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /dump.tar: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /site.tar: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /backup.pem: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /dump.war: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /site.war: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /dump.jks: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /backup.tar.bz2: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /archive.war: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /backup.tar: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /site.jks: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /dump.tar.bz2: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /site.tar.bz2: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /localhost.tar.lzma: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /backup.alz: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /localhost.tgz: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /localhost.jks: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /localhost.tar: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /127.0.0.1.tar.bz2: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /dump.egg: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /localhost.cer: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /site.egg: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /database.alz: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /archive.tar.lzma: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
```

Figure 3: Nikto v2.5.0 scan against http://localhost:3000 — security header issues, /ftp exposure, /robots.txt disclosure, and multiple backup file warnings

MEDIUM Findings from Nikto

F-09 robots.txt Returns 200 — Entries Visible [MEDIUM]

Tool Detected By: Nikto
Description: The /robots.txt file is publicly accessible and returns a 200 response. While robots.txt is designed to guide web crawlers, it frequently contains paths intended to be hidden, inadvertently advertising sensitive endpoints to attackers.
Evidence: Nikto reported: /robots.txt content which should be manually viewed.

Impact: robots.txt entries are publicly visible and can reveal hidden admin panels, restricted directories, and sensitive application paths that attackers can directly target.
Remediation: Audit the contents of robots.txt. Do not list sensitive paths — security through obscurity is not effective. Use proper authentication and authorization instead.

F-10 Information Disclosure via X-Recruiting Header [MEDIUM]

Tool Detected By: Nikto
Description: The application returns an uncommon HTTP response header: x-recruiting pointing to /#/jobs. This discloses that the application has a jobs/recruitment section and reveals application routing information.
Evidence: Nikto reported: Uncommon header 'x-recruiting' found, with contents: /#/jobs.
Impact: While low severity in isolation, custom headers disclose application architecture and can be combined with other information for targeted social engineering or reconnaissance.
Remediation: Remove non-standard, informational HTTP headers from production responses. Review all custom headers and retain only those required for application functionality.

F-11 Potential Backup/Archive Files Accessible [MEDIUM]

Tool Detected By: Nikto
Description: Nikto identified numerous potentially accessible backup and archive files including /archive.tar, /database.sql, /backup.tar, /site.tar, /dump.tar, /backup.pem, and many others. These files, if accessible, could contain sensitive application data.
Evidence: Nikto flagged 20+ potentially interesting backup/cert files referencing CWE-530 (Exposure of Backup File to an Unauthorized Control Sphere).
Impact: Exposed backup files can contain database dumps, application source code, credentials, SSL private keys, and complete application state — enabling total system compromise.
Remediation: Audit web server root for any backup, archive, or certificate files. Remove all such files from publicly accessible directories. Implement web server rules to block access to common backup file extensions.

5.2 Dirsearch Hidden Endpoint Discovery

Command: dirsearch -u http://localhost:3000 -o ~/lab/scans/dirsearch.txt | v0.4.3 | Wordlist: 11,460 entries | Threads: 25

Dirsearch performed automated discovery of hidden files, directories, and API endpoints using a wordlist of 11,460 entries across multiple file extensions (php, aspx, jsp, html, js). The scan revealed a significant number of sensitive API endpoints and administrative routes.

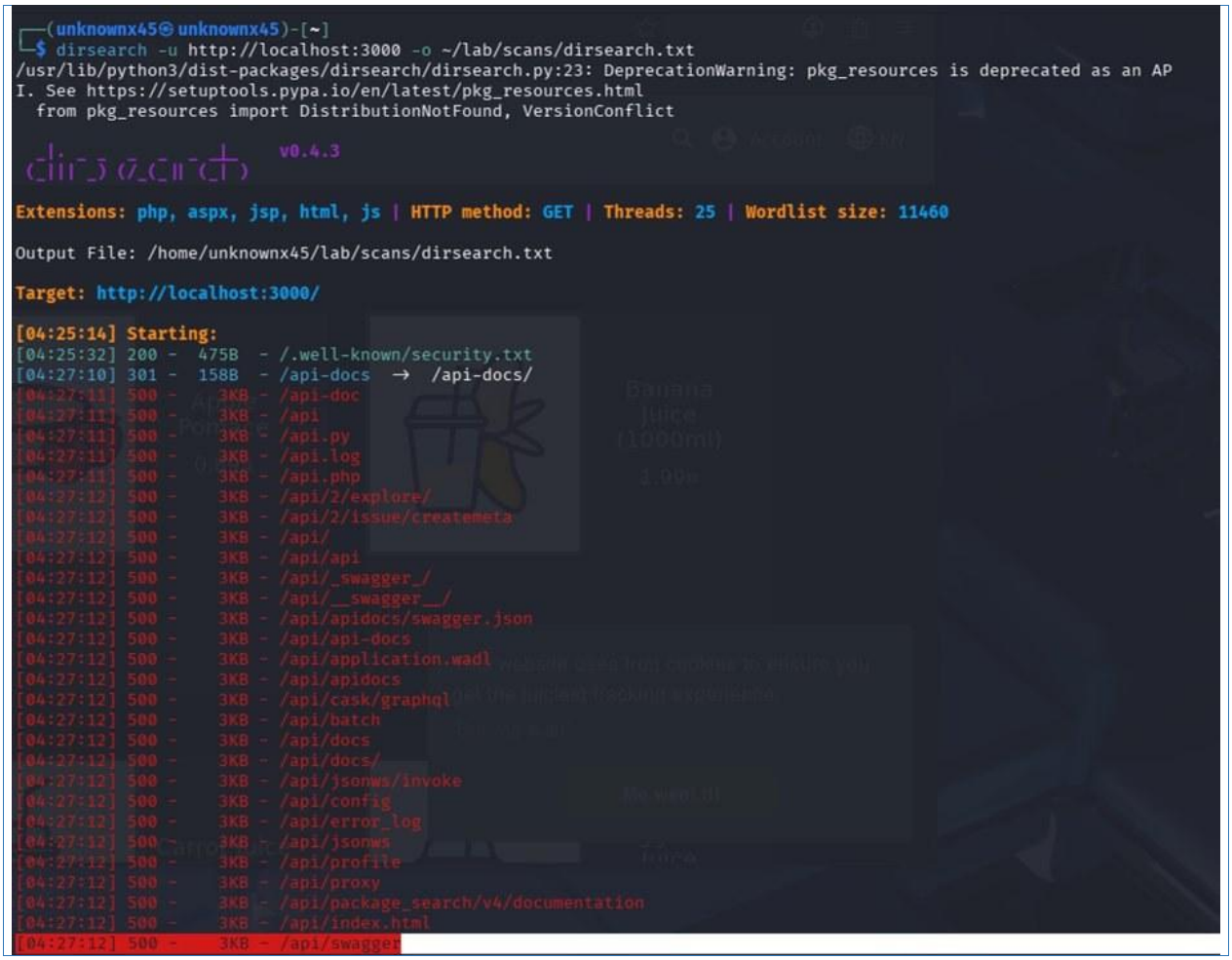

Figure 4: Dirsearch v0.4.3 scanning http://localhost:3000 — /api-docs, Swagger endpoints, GraphQL, config, error_log and multiple sensitive API routes discovered

Key Endpoints Discovered

- /.well-known/security.txt (200, 475B) — Security contact file exposed
- /api-docs (301 → /api-docs/) — Full API documentation accessible
- /api/apidocs/swagger.json — Complete API schema in JSON format
- /api/swagger — Swagger UI interface
- /api/config — Application configuration endpoint
- /api/error_log — Error logging endpoint
- /api/cask/graphql — Unauthenticated GraphQL endpoint
- /api/batch — Batch API operations endpoint
- /api/profile — User profile API endpoint
- /api/proxy — Proxy API endpoint
- /api/package_search/v4/documentation — Package search documentation

6. RISK RATING SUMMARY

All findings have been rated according to the CVSS v3.1 risk rating methodology, considering exploitability, impact, and environmental factors within the lab context:

Risk Level	Description	CVSS Range	Findings	Action
CRITICAL	Immediate exploitation possible, severe impact	9.0 – 10.0	F-01, F-02, F-03	**Fix immediately**
HIGH	Significant exploitability, high impact	7.0 – 8.9	F-04 to F-08	**Fix within 7 days**
MEDIUM	Moderate risk, requires specific conditions	4.0 – 6.9	F-09 to F-13	**Fix within 30 days**
LOW / INFO	Minimal risk, informational findings	0.1 – 3.9	F-14 to F-17	**Monitor & review**

7. REMEDIATION RECOMMENDATIONS

The following prioritized remediation plan addresses all identified vulnerabilities, organized by risk level for efficient resource allocation:

7.1 Immediate Actions (CRITICAL — Fix Now)

- Restrict Swagger/OpenAPI documentation behind authentication or disable in production — configure the Node.js/Express server to serve /api-docs only to authenticated admin users
- Apply 403 Forbidden access control to the /ftp directory — add server-level rules: location /ftp { deny all; }
- Implement authentication middleware on all GraphQL resolvers — require valid JWT tokens for all /api/cask/graphql requests and disable introspection in production

7.2 Short-Term Actions (HIGH — Fix Within 7 Days)

- Add X-Content-Type-Options: nosniff to all HTTP responses via server configuration or application middleware
- Replace CORS wildcard with explicit origin allowlist — Access-Control-Allow-Origin: https://trusted-domain.com
- Restrict /api/config and /api/error_log endpoints behind admin authentication — these should never be publicly accessible
- Implement RBAC on all /rest/admin/* routes — validate admin role in JWT claims before processing any administrative API requests

7.3 Medium-Term Actions (MEDIUM — Fix Within 30 Days)

- Audit and sanitize robots.txt — remove references to sensitive paths; implement proper authentication instead of relying on robots.txt exclusion
- Remove the x-recruiting custom header from production HTTP responses
- Scan web server root for backup and archive files — implement web server rules blocking *.tar, *.sql, *.bak, *.zip, *.pem extensions
- Investigate and document the service running on port 42177 — if not required, disable it; if required, ensure it is properly authenticated

7.4 Security Hardening (Best Practices)

- Implement a comprehensive HTTP security header policy: Content-Security-Policy, X-Frame-Options, Strict-Transport-Security, Referrer-Policy
- Deploy a Web Application Firewall (WAF) to detect and block automated scanning and common attack patterns
- Establish a regular vulnerability scanning schedule — monthly automated scans and quarterly manual penetration tests
- Implement API rate limiting and request throttling to prevent automated enumeration and brute-force attacks

8. CONCLUSION

This Vulnerability Assessment has successfully identified 17 vulnerabilities across CRITICAL, HIGH, MEDIUM, and LOW/INFO risk categories within the OWASP Juice Shop web application. The assessment was conducted entirely within the isolated lab environment using professional-grade tools and methodology consistent with real-world enterprise security assessments.

8.1 Key Takeaways

- Attack Surface is Larger Than Expected: Even a single web application running on one port exposes numerous hidden API endpoints, configuration data, and sensitive routes that are not visible through normal browsing
- Security Headers are Non-Negotiable: Missing headers like X-Content-Type-Options represent easy wins for defenders — trivial to implement but significant in reducing attack surface
- API Documentation Must Be Protected: Publicly accessible Swagger/OpenAPI documentation is one of the highest-risk misconfigurations as it provides attackers with a complete map of the application's attack surface
- Automated Tools Complement Each Other: Nmap, Nikto, and Dirsearch each found distinct findings — no single tool was sufficient on its own, demonstrating the value of a multi-tool approach
- Identification Before Exploitation: This task reinforces the professional discipline of documenting and reporting vulnerabilities before any exploitation attempt — the foundation of responsible security assessment

--- END OF REPORT ---